



Автор: Люциан Константин
Старший писатель CSO

Червь ChainDrop, похищающий учетные данные, заражает более 400 пакетов npm

Новости

4 августа 2026 года • 5 минут

Радиус действия варианта Shai Hulud на данный момент включает в себя несколько очень популярных пакетов. Командам по обеспечению безопасности настоятельно рекомендуется провести полную проверку всех компьютеров разработчиков.



Самораспространяющаяся червеобразная атака затронула реестр npm, заразив на данный момент 444 пакета от более чем десятка издателей. Последствия огромны: общее количество загрузок затронутых пакетов превышает 2 миллиарда в месяц.

Атака началась со взлома аккаунта на GitHub, принадлежащего Джареду Рэю, который ведет Keyv — пакет, который скачивают более 150 миллионов раз в неделю и который предоставляет интерфейс для взаимодействия с хранилищем «ключ-значение» на нескольких бэкендах. Версия 6.0.0, опубликованная около 9:00 по всемирному координированному времени во вторник, содержала новую версию вредоносного ПО **Shai-Hulud** [<https://www.csoonline.com/article/4179866/infected-red-hat-npm-packages-expose-developer-credentials.html>], предназначенного для кражи учетных данных.

Взломанная учетная запись также используется для поддержки ряда других популярных пакетов, в том числе cacheable, flat-cache, file-entry-cache, cacheable-request, cache-manager, ecto и других. Все они также содержали троянизированные версии.

Вскоре после этого атака распространилась за пределы этого аккаунта и затронула пакеты других организаций на npm — @deliveroo/reevent, @or-sdk/invitations, @picsart/ai-sdk, @qlik/embed-runtime, picasso.js и многие другие. По состоянию на 18:10 UTC компания StepSecurity **обнаружила вредоносный код в 444 пакетах и 2212 версиях** [<https://www.stepsecurity.io/blog/chaindrop-npm-worm>].

«Каждая зараженная версия имеет один и тот же сценарий заражения: предустановленный дроппер, который загружает легитимную среду выполнения Bun JavaScript, и второй этап размером 710 КБ, который обфусцирует код, крадет учетные данные, публикует новые вредоносные пакеты и внедряется в инструменты для разработчиков ИИ», — сообщили исследователи из StepSecurity.

Несмотря на то, что код, по всей видимости, является новым вариантом Shai-Hulud — червя, крадущего учетные данные в цепочке поставок, который с прошлого года в различных вариациях распространялся в репозиториях npm и PyPI, — исследователи решили назвать эту новую атаку ChainDrop, поскольку в этой версии для управления и контроля используется блокчейн Ethereum — метод, известный как EtherHiding.

«Взлом был осуществлен путем отправки вредоносных файлов непосредственно в основную ветку, после чего сразу же выпускалась новая версия. Таким образом, зараженные версии публиковались в npm с действительным происхождением, подтвержденным GitHub Actions», — сообщили исследователи из Aikido Security в **отчете** [<https://www.aikido.dev/blog/keyv-and-friends-compromised-in-npm-supply-chain-attack>].

Рэй подтвердил в X, что использует OpenID Connect (OIDC) с npm и одноразовые коды для GitHub, поэтому он не использовал долгосрочные статические токены.

Разработчик восстановил доступ к своей учетной записи GitHub около 20:00 по всемирному координированному времени и заявил, что проводит полную проверку [<https://x.com/jaredwray/status/2084735469359935697>].

Вредоносное ПО заражает ИИ-помощников

Вредоносные файлы, добавляемые в пакеты, — это `setup.mjs` и `Math_Symbol.js` — в некоторых случаях они переименованы в `math_init.js`. Они запускаются предустановочным скриптом во время установки пакетов через `npm`, а затем загружают и запускают на компьютере вторичную обфусцированную полезную нагрузку.

Вредоносная программа ищет в локальной среде учетные данные для доступа к облаку, секреты инфраструктуры, токены доступа разработчиков, файлы конфигурации, связанные с искусственным интеллектом, и криптовалютные кошельки. Она также определяет рабочие процессы CI/CD и средства сборки и пытается извлечь из их памяти временные секреты, введенные в процессе сборки.

New to this variant are persistent mechanisms deployed inside code editors such as VS Code via `tasks.json` and AI code assistants such as Claude Code through hooks.

“Targets for credential theft have been expanded by almost 70%, with new additions including AI-agent credential stores for Claude, OpenAI, Codex, Cursor and Gemini; cryptocurrency keystores for Foundry, Solana and Monero; self-hosted CI and registry secrets such as Jenkins’ master.key, Argo CD and Harbor; Alibaba Cloud and Tencent Cloud CLI configurations; and system files including `/etc/shadow`,” researchers from security firm Wiz said in their own analysis [<https://www.wiz.io/blog/keyv-and-cacheable-npm-supply-chain-attack>].

Mitigation

Unfortunately, enterprise security teams must perform full audits of developer machines. The compromised packages are transient dependencies for thousands of others and if any of the poisoned versions were installed during the attack window, all possible credentials accessible on that machine, or other machines accessible from that machine, need to be rotated.

“Rotate, at minimum: npm automation tokens, GitHub personal access tokens and SSH keys, cloud provider credentials (`~/.aws`, `~/.config/gcloud`, Azure), Kubernetes service accounts, and any secrets in environment variables or `.env` files present at install time,” the StepSecurity researchers said. “Maintainers of npm packages should treat their publish credentials as exposed. The second wave of this campaign demonstrates exactly why: additional maintainer accounts published the identical payload within the same hour.”

The StepSecurity report includes indicators of compromise, a list of infected packages, as well as defense-in-depth recommendations for developer machines and processes that could have stopped this compromise.

Using the `--ignore-scripts` npm flag in CI workflows, a technique known as script gating, would have ignored the `preinstall` script that delivers the payload. Package managers like npm, pnpm, Yarn and Bun now support minimum release age policies for package installation. Configuring this setting to between 3 to 7 days buys users some time in case a newly released version turns out to be poisoned.

Security companies continuously scan and monitor the npm registry and new supply chain compromises are usually discovered within minutes or hours. In this case the malicious versions began being removed by the npm team within two hours, but being a worm, the attack keeps propagating via newly compromised developer accounts.

[Software Development](https://www.csoonline.com/software-development/)

[Cyberattacks](https://www.csoonline.com/cyberattacks/)

[Cybercrime](https://www.csoonline.com/cybercrime/)

[Security](https://www.csoonline.com/security/)

[Malware](https://www.csoonline.com/malware/)

About

Policies

More

Our Network

